MedData Solutions

Healthcare Technology
Malaga, Spain

2-Year Cybersecurity Investment Plan

2026 - 2028

PREPARED by

MedData Solutions

Lorela Elezaj, CEO
Luis Enrique Landaverde, CISO

PREPARED DATE
Feb 23, 2026

EXP. DATE
Feb 23, 2028

ITEM	QTY	PRICE(ANNUAL)	TOTAL
Cybersecurity Architect (DD-WRL-001)	1	€78,000	€156,000
Internal Workforce Training & Certifications (3 Staff)	3	€6,667	€20,000
External Regulatory Audit (ISO/NIS2 Compliance)	2	€15,000	€30,000
Security Tooling (EDR + Cloud Security Licenses)	U	€12,500	€25,000
External DFIR and Malware Analysis Service Contract	2	€7,500	€15,000
Strategic contingency reserve	1	€4,000	€4,000
			€250,000

1. External Hire Justification – DD-WRL-001 Cybersecurity Architect

Required Characteristics

Technical

- 5+ years in cloud security
- AWS/Azure architecture experience
- Zero Trust understanding
- Experience with healthcare data protection
- Threat modeling expertise
- Secure SDLC implementation

Certifications (Preferred)

- CISSP or CCSP
- AWS Security Specialty
- Azure Security Engineer
- ISO 27001 Lead Implementer (optional)

Soft Skills

- Risk communication to board
- Architecture documentation
- Ability to mentor internal staff
- Strategic mindset (not just technical)

Role Definition and Strategic Rationale

To achieve the transition from a reactive security posture to a proactive, security-by-design operational model, the organization will hire one Cybersecurity Architect (DD-WRL-001) under the NICE Framework (Design & Development category).

The Cybersecurity Architect is responsible for defining and implementing enterprise-wide security architecture, integrating security controls into cloud infrastructure, development processes, and network segmentation models. This role introduces structured threat modeling, formalizes secure SDLC practices, and ensures security controls are embedded at the design stage rather than retroactively applied after incidents.

This position is critical given the company's profile as:

- A Healthcare SaaS provider
- Processing sensitive personal and medical data

- Operating under GDPR and NIS2 regulatory requirements
- Utilizing a predominantly cloud-first infrastructure

Without a dedicated architecture-level security function, the organization remains exposed to systemic risks such as cloud misconfigurations, lateral movement pathways, insecure API integrations, and fragmented control implementation.

The Cybersecurity Architect directly addresses these structural vulnerabilities.

Compensation and Cost Structure

The projected gross annual salary for a mid-level Cybersecurity Architect in Spain is estimated at:

€60,000 gross per year

Including employer contributions (social security and associated costs estimated at approximately 30%), the total annual company cost is:

Approximately €78,000 per year

Over a 2-year strategic planning horizon, the total projected cost is:

€156,000 – €160,000

This compensation level reflects a mid-level architect profile appropriate for a medium-sized healthcare SaaS company. It is competitive within the Spanish cybersecurity labor market while remaining financially sustainable under the fixed €250,000 two-year investment cap.

The compensation is intentionally positioned below senior enterprise-architect levels (typically €80,000–€100,000 gross), as the company requires operational architecture leadership rather than multinational-scale governance oversight.

Risk Reduction Impact

The addition of a Cybersecurity Architect significantly reduces systemic organizational risk through:

Security-by-Design Implementation

- Integration of security controls during system design
- Reduction of inherited technical debt

Cloud Security Hardening

- Implementation of secure reference architectures
- Identity and access control standardization
- Segmentation and Zero Trust principles

Threat Modeling

- Identification of high-impact attack vectors before deployment

- Reduction in exploitability of new features

Regulatory Alignment

- Alignment with GDPR data protection by design principles
- Structured documentation supporting NIS2 compliance

By addressing security at the architectural layer, the probability of ransomware propagation, lateral movement, and systemic compromise is substantially reduced. This produces a compounding risk-reduction effect over the 2-year period.

Strategic Investment Justification

Although this role represents the largest portion of the budget allocation, it provides the highest long-term impact on organizational resilience.

The cost of a single major ransomware incident in the healthcare sector frequently exceeds €1 million when accounting for downtime, legal exposure, data recovery, and reputational damage. The €160,000 investment over two years is therefore justified as a preventive measure that reduces the likelihood and severity of such events.

This hire is not an operational expansion of alert monitoring but a structural transformation toward a mature cybersecurity governance model.

2. Internal Workforce Development and Training Justification

Strategic Objective for Internal Training

A central pillar of the 2-year cybersecurity transformation plan is structured workforce development aligned with the NICE Framework. Rather than expanding headcount beyond budget constraints, MedData Solutions will upskill three internal professionals to expand role coverage across Protection & Defense (PD) and Oversight & Governance (OG) functions.

This approach:

- Maximizes NICE role coverage using existing staff
- Reduces reliance on external providers
- Strengthens internal resilience and operational continuity
- Maintains financial discipline within the €250,000 two-year investment cap

The total projected investment in workforce development remains €20,000 over two years.

Training Role Assignment Model (Equal Split of Purple Training Roles)

The organization has eight targeted training roles (four OG roles and four PD roles). These are distributed equally across the four cybersecurity participants (three internal staff plus the new hire) at two training roles per person.

Assigned training roles (2 each):

- New Hire (DD-WRL-001 - Cybersecurity Architecture):
  OG-WRL-002 (Cybersecurity Policy and Planning) + OG-WRL-016 (Technology Program Auditing)

- Internal - IO-WRL-005 (Systems Administration):
  PD-WRL-004 (Infrastructure Support) + OG-WRL-012 (Security Control Assessment)

- Internal - IO-WRL-002 (Database Administration):
  OG-WRL-008 (Privacy Compliance) + PD-WRL-007 (Vulnerability Analysis)

- Internal - PD-WRL-001 (Defensive Cybersecurity):
  PD-WRL-003 (Incident Response) + PD-WRL-006 (Threat Analysis)

-

1. SOC and Incident Response Maturity

Transition: PD-WRL-001 (Defensive Cybersecurity) -> PD-WRL-003 (Incident Response) + PD-WRL-006 (Threat Analysis)

1.1 Training Components

Year 1:
- Advanced SIEM engineering (Splunk / Sentinel)
- MITRE ATT&CK mapping and detection rule development
- Incident response frameworks (NIST 800-61)
- Threat hunting methodology

Year 2:
- Threat intelligence analysis and triage workflows
- Log correlation optimization and detection tuning
- Incident coordination simulations
- Ransomware tabletop exercises

Estimated cost: €7,000

Strategic Justification
- Improves Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR)
- Reduces attacker dwell time through faster containment and recovery
- Enables higher-fidelity detection through threat-context enrichment

Certification / Training	Role alignment	Year	Estimated cost	Why it fits
Microsoft SC-200	PD-WRL-003, PD-WRL-006	1	**€165**	Strong fit for SOC analysts and incident responders working with **Microsoft Sentinel**, alert triage, investigation, and response workflows.
Security Blue Team BTL1	PD-WRL-003	1	**€600**	Practical foundation for **log analysis, alert triage, basic incident handling, and blue-team operations**. Good entry point for structured SOC work.
MITRE ATT&CK Defender modules	PD-WRL-001, PD-WRL-003, PD-WRL-006	1	**€1,200**	Directly supports **ATT&CK mapping, detection engineering, adversary behavior analysis, and threat hunting**, which matches your Year 1 focus.
SIEM labs / detection engineering practice	PD-WRL-001, PD-WRL-003	1	**€1,235**	Covers hands-on **Splunk/Sentinel practice, rule tuning, log correlation, and detection validation**. This is where real skill gets built.
Splunk Core Power User / Splunk Admin	PD-WRL-001, PD-WRL-003	2	**€150**	Good if your environment uses **Splunk**. Supports search, dashboards, data handling, and more advanced SIEM operations.
Security Blue Team BTL2	PD-WRL-003, PD-WRL-006	2	**€2,100**	Stronger advanced blue-team cert focused on **threat hunting, deeper investigations, detection maturity, and incident analysis**.
CompTIA CySA+	PD-WRL-001, PD-WRL-003	2	**€400**	Broad defensive certification that reinforces **SOC operations, incident detection, vulnerability awareness, and analytics**. Useful as a recognized mid-tier credential.
IR simulations / ransomware tabletop workshops	PD-WRL-003, PD-WRL-006	2	**€650**	Supports **incident coordination, escalation, decision-making, and response readiness**. This maps directly to your simulation and ransomware exercise goals.
Budget reserve (retakes / price changes / VAT)	Cross-role support	2	**€500**	Prevents the plan from collapsing if prices shift, a retake is needed, or extra exam fees appear.

1.2 Certification and Professional Development Roadmap

To support the transition from PD-WRL-001 (Defensive Cybersecurity) toward PD-WRL-003 (Incident Response) and PD-WRL-006 (Threat Analysis), a structured two-year certification and professional development roadmap is proposed. This roadmap is designed not only to validate knowledge through recognized credentials, but also to strengthen the practical and operational capabilities required for more advanced blue-team, incident response, and threat analysis functions.

In the first year, the primary objective is to consolidate the foundational competencies required in a modern Security Operations Center (SOC) environment. This stage focuses on strengthening core capabilities in SIEM operation, detection engineering, ATT&CK-based analysis, incident triage, and threat hunting. Certifications such as Microsoft SC-200 and Security Blue Team BTL1 provide a strong baseline for developing operational skills related to alert investigation, log analysis, and initial incident response activities. In parallel, specialized MITRE ATT&CK Defender training modules reinforce the ability to map adversary techniques, improve detection logic, and align defensive monitoring with established threat models. This first phase is further supported by dedicated SIEM laboratory practice, allowing the learner to apply theoretical concepts in realistic technical environments and to build practical confidence in detection tuning, query development, and correlation workflow optimization.

In the second year, the roadmap advances toward deeper investigative and analytical responsibilities associated with mature incident response and threat analysis roles. At this stage, the emphasis shifts from foundational monitoring and triage toward more advanced competencies such as coordinated incident handling, detection refinement, intelligence-driven analysis, and complex threat investigation. Certifications such as Security Blue Team BTL2, together with Splunk Power User or Splunk Admin, strengthen technical depth in threat hunting, SIEM optimization, and advanced blue-team workflows. The inclusion of CompTIA CySA+ adds a broader defensive and analytical certification layer, reinforcing knowledge in threat detection, incident analysis, and security operations. In addition, ransomware tabletop exercises and incident coordination simulations are incorporated to ensure that technical skill development is complemented by decision-making, communication, and response management capabilities under realistic operational pressure.

This roadmap is intentionally designed as a capability-development strategy rather than a simple collection of certifications. The selected certifications and training activities complement one another and collectively support progression from general defensive cybersecurity responsibilities into more specialized roles in incident response and threat analysis. By combining formal credentials, targeted technical training, hands-on lab experience, and simulation-based exercises, the roadmap creates a balanced pathway that aligns professional growth with the workforce roles identified in this development plan.

From a budgetary perspective, the estimated investment of €7,000 is considered proportionate and justified. This amount covers certification exams, specialized training modules, hands-on SIEM practice, simulation exercises, and a contingency reserve for retakes or cost fluctuations. As a result, the investment contributes not only to formal qualification, but also to the development of practical operational maturity, ensuring that the training effort remains sustainable, relevant, and directly aligned with the intended career progression.

2. Privacy Compliance and Vulnerability Management (Data-Centric)

Transition: IO-WRL-002 (Database Administration) -> OG-WRL-008 (Privacy Compliance) + PD-WRL-007 (Vulnerability Analysis)

2.1 Training Components

Certification / Training	Role alignment	Year	Estimated cost	Why it fits
CompTIA Security+	IO-WRL-002, PD-WRL-007	1	**€380**	Foundational security baseline for vulnerability, access control, and risk concepts.
Tenable / Nessus vulnerability assessment training	PD-WRL-007	1	**€500**	Supports vulnerability discovery, prioritization, and remediation workflows.
CIS Benchmarks / Secure Configuration training	IO-WRL-002, PD-WRL-007	1	**€800**	Directly supports secure baseline implementation for database platforms and services.
Database hardening and access control labs	IO-WRL-002, PD-WRL-007	1	**€1,120**	Practical training in secure configuration, privilege review, and technical remediation.
Privacy engineering / CDPSE-oriented training	OG-WRL-008	2	**€1,300**	Strong fit for privacy-by-design, governance alignment, and control evidence preparation.
GDPR practitioner / privacy compliance fundamentals	OG-WRL-008	2	**€900**	Supports records of processing, minimization, retention, and privacy readiness.
Privacy-by-design workshops for schemas and data flows	OG-WRL-008, IO-WRL-002	2	**€550**	Connects compliance requirements to actual schema and data flow decisions.
Audit evidence and control documentation training	OG-WRL-008, PD-WRL-007	2	**€650**	Improves audit defensibility through stronger records, evidence, and safeguard documentation.
Budget reserve (retakes / price changes / VAT)	Cross-role support	2	**€300**	Keeps the roadmap realistic if costs move slightly.

Year 1:

- Vulnerability management lifecycle (CVE, CVSS, remediation tracking)
- Secure configuration baselines (CIS Benchmarks) for database services
- Database security hardening and access control review
- Patch governance processes and change control

Year 2:

- GDPR-aligned privacy compliance fundamentals (records of processing, data minimization, retention)
- Privacy-by-design support for database schemas and data flows
- Control evidence preparation for privacy-related safeguards

Estimated cost: €6,500
Strategic Justification

- Reduces exploitability of data stores through continuous vulnerability reduction
- Strengthens privacy compliance readiness for healthcare data handling
- Improves audit defensibility via documented hardening and evidence

2.2 Certification and Professional Development Roadmap

To support the transition from **IO-WRL-002 (Database Administration)** toward **OG-WRL-008 (Privacy Compliance)** and **PD-WRL-007 (Vulnerability Analysis)**, a structured two-year certification and professional development roadmap is proposed. This pathway is designed to strengthen both the technical and governance-oriented competencies required to reduce database-related security exposure while improving privacy compliance readiness in environments handling sensitive or regulated information.

In the first year, the roadmap focuses on building the technical foundation required for vulnerability reduction and secure database administration. This phase emphasizes the vulnerability management lifecycle, including the identification, prioritization, remediation, and tracking of weaknesses through established practices such as CVE and CVSS-based analysis. Training in vulnerability assessment tools and secure configuration standards, combined with practical database hardening laboratories, supports the development of skills in remediation planning, secure baseline implementation, privilege control, and access review. The inclusion of secure configuration training aligned with **CIS Benchmarks** is particularly relevant, as it strengthens the ability to establish defensible hardening baselines for database services. This first phase therefore reinforces the transition from traditional database administration responsibilities into a more security-focused role centered on vulnerability reduction and technical control improvement.

In the second year, the roadmap advances toward privacy governance and compliance-oriented capabilities. At this stage, the emphasis expands beyond technical hardening to include data protection principles, privacy-by-design practices, and the preparation of defensible compliance evidence. Training in **GDPR-aligned privacy compliance fundamentals** provides the knowledge required to support key obligations such as records of processing, data minimization, retention controls, and privacy-related safeguards. In parallel, privacy engineering or **CDPSE-oriented** learning strengthens the ability to integrate privacy requirements into database schemas, data flows, and control design decisions. This second phase is complemented by targeted work in audit evidence preparation and documentation,

ensuring that implemented safeguards can be demonstrated clearly and consistently during compliance reviews or external audits.

This roadmap is intentionally designed as a capability-development strategy rather than a simple list of certifications. The selected certifications and training activities complement one another by combining technical vulnerability management, secure configuration, database hardening, privacy compliance fundamentals, and audit-oriented documentation practices. As a result, the pathway directly supports progression from infrastructure-focused database responsibilities toward broader responsibilities in privacy compliance and vulnerability analysis.

From a strategic perspective, this investment is justified because it contributes to three key organizational outcomes. First, it reduces the exploitability of data stores through continuous vulnerability identification, remediation, and hardening. Second, it improves privacy compliance readiness, especially in environments that process healthcare or other sensitive personal data, by strengthening the application of data minimization, retention, and privacy-by-design principles. Third, it increases audit defensibility by improving the documentation, traceability, and evidentiary quality of implemented safeguards. The estimated **€6,500 budget** is therefore proportionate and justified, as it supports not only certification and training acquisition, but also the development of sustainable operational maturity across both security and privacy domains.

3. Infrastructure Hardening and Internal Control Assessment

Transition: IO-WRL-005 (Systems Administration) -> PD-WRL-004 (Infrastructure Support) + OG-WRL-012 (Security Control Assessment)

Year 1:
- Cloud security fundamentals (AWS/Azure security track)
- CIS baseline implementation and configuration management
- EDR deployment and tuning

Year 2:
- Zero Trust architecture principles and segmentation basics
- Secure IAM implementation support
- Security control validation methods (evidence collection, testing cadence, reporting)

Estimated cost: €6,500

Strategic Justification
- Reduces misconfiguration risk and improves endpoint hardening
- Creates repeatable control validation and evidence for audits
- Reduces lateral movement probability through stronger infrastructure controls

3.1 Training Components

Certification / Training	Role alignment	Year	Estimated cost	Why it fits
AZ-500 or AWS Security Specialty (cloud security track)	IO-WRL-005, PD-WRL-004	1	**€300**	Establishes cloud security fundamentals for secure infrastructure support and reduces cloud misconfiguration exposure.
CIS Baselines and configuration management training	IO-WRL-005, PD-WRL-004	1	**€850**	Supports consistent hardening, baseline enforcement, and configuration governance.
EDR deployment and tuning labs	PD-WRL-004	1	**€1,300**	Builds practical experience in endpoint protection rollout, tuning, and monitoring.
Infrastructure hardening workshops (OS, server, endpoint)	IO-WRL-005, PD-WRL-004	1	**€850**	Reinforces host hardening, service minimization, and secure administration practices.
Zero Trust architecture and segmentation training	PD-WRL-004, OG-WRL-012	2	**€1,000**	Reduces lateral movement risk and strengthens infrastructure control design.
Secure IAM implementation support training	PD-WRL-004, OG-WRL-012	2	**€850**	Improves role-based access, identity hygiene, and privilege control.
Security control assessment and validation training	OG-WRL-012	2	**€650**	Supports evidence collection, control testing, and repeatable validation methods.
Audit evidence, testing cadence, and reporting workshops	OG-WRL-012, PD-WRL-004	2	**€450**	Strengthens audit readiness through structured reporting and documented control review.
Budget reserve (retakes / price changes / VAT)	Cross-role support	2	**€250**	Preserves flexibility if prices or exam fees shift slightly.

3.2 Certification and Professional Development Roadmap

To support the transition from **IO-WRL-005 (Systems Administration)** toward **PD-WRL-004 (Infrastructure Support)** and **OG-WRL-012 (Security Control Assessment)**, a structured two-year certification and professional development roadmap is proposed. This pathway is designed to strengthen technical hardening capabilities while also building the internal assessment discipline required to validate, document, and sustain effective infrastructure security controls.

In the first year, the roadmap focuses on reducing baseline technical risk through stronger infrastructure hardening and improved operational security practices. This phase emphasizes cloud security fundamentals, secure configuration baselines, endpoint protection deployment, and repeatable hardening procedures across systems and services. A cloud-security certification track such as **AZ-500** or **AWS Security Specialty** supports the development of practical knowledge in implementing security controls, maintaining secure cloud posture, and addressing infrastructure-related vulnerabilities in modern hybrid environments. In parallel, training in **CIS baseline implementation**, configuration management, and infrastructure hardening reinforces the ability to standardize secure settings, reduce configuration drift, and improve the consistency of system administration practices. The inclusion of **EDR deployment and tuning labs** is especially important, as it builds hands-on capability in endpoint hardening, protection policy adjustment, and operational monitoring, directly reducing misconfiguration and endpoint exposure.

In the second year, the roadmap advances from pure hardening into more mature control-oriented responsibilities. At this stage, the emphasis shifts toward **Zero Trust principles**, segmentation fundamentals, secure identity and access implementation, and systematic control validation. Training in Zero Trust and segmentation helps reduce the probability of lateral movement by promoting stronger isolation, access restriction, and trust minimization across the infrastructure. Complementary work in **secure IAM implementation** strengthens role-based access control, privilege management, and identity governance, which are essential for both infrastructure support and control effectiveness. In addition, focused training in **security control assessment and validation methods** develops the ability to collect evidence, test controls on a defined cadence, and produce structured findings and reports that can withstand internal review or audit scrutiny.

This roadmap is intentionally designed as a capability-development strategy rather than a random collection of certifications. The selected certifications and training activities complement one another by combining infrastructure hardening, endpoint protection, identity control, segmentation, and internal validation practices into a coherent progression. As a result, the pathway directly supports movement from systems administration responsibilities into stronger infrastructure security support and more formal security control assessment functions.

From a strategic perspective, this investment is justified because it contributes to three concrete organizational outcomes. First, it reduces misconfiguration risk and improves endpoint hardening through standardized baselines, stronger configuration management, and better EDR deployment practices. Second, it creates repeatable control validation and defensible evidence for audits by introducing formalized testing, documentation, and reporting practices. Third, it reduces the probability of lateral movement by strengthening infrastructure segmentation, identity controls, and Zero Trust-aligned access design. The estimated **€6,500 budget** is therefore proportionate and justified, as it supports both technical hardening maturity and the development of sustainable internal control assessment capability.

4. Financial Efficiency of the Training Model

Hiring three additional specialists would exceed the available budget over a two-year period. Instead, a targeted €20,000 training investment expands NICE coverage across:
• PD-WRL-003 (Incident Response)
• PD-WRL-004 (Infrastructure Support)
• PD-WRL-006 (Threat Analysis)
• PD-WRL-007 (Vulnerability Analysis)
• OG-WRL-002 (Cybersecurity Policy and Planning)
• OG-WRL-008 (Privacy Compliance)
• OG-WRL-012 (Security Control Assessment)
• OG-WRL-016 (Technology Program Auditing)

5. Risk Reduction Impact

Collectively, the training strategy:

- Reduces ransomware propagation risk through improved hardening and segmentation support
- Reduces dwell time via improved detection, triage, and response execution
- Reduces vulnerability exploitation windows for endpoints and data stores
- Improves audit readiness through documented control validation and evidence
- Strengthens privacy compliance posture for sensitive healthcare data

3. Security Tooling and Technology Investment Justification

Strategic Rationale for Technology Modernization

While workforce capability forms the foundation of the 2-year cybersecurity strategy, technical controls and automation are essential to operationalize those capabilities on a scale. A mid-size healthcare SaaS organization managing approximately 450 employees and sensitive patient data cannot rely solely on manual monitoring and configuration processes.

The allocated **€25,000 over two years** for security tooling is designed to:

- ❖ Enhance detection and response capabilities
- ❖ Improve cloud security visibility
- ❖ Reduce manual workload on security personnel
- ❖ Increase the efficiency of internal NICE role coverage
- ❖ Strengthen regulatory compliance posture

This investment is intentionally moderate, reflecting incremental enhancement rather than complete infrastructure replacement.

1. Endpoint Detection and Response (EDR)

Functional Purpose

EDR solutions provide behavioral monitoring, anomaly detection, and automated containment capabilities across endpoint devices. Given the organization's reliance on cloud-connected endpoints and administrative systems, endpoint visibility is a critical defensive layer.

Operational Benefits

Behavioral ransomware detection
Lateral movement detection
Suspicious authentication alerts
Automated isolation of compromised devices
Forensic telemetry collection

Without EDR, detection would depend solely on manual log review, significantly increasing attacker dwell time.

Financial Justification

Assuming approximately 450 endpoints, with partial existing licensing infrastructure, the incremental expansion cost is estimated at:

Approx. €3–4 per endpoint per month (blended estimate)

Adjusted for existing tooling baseline

Total projected 2-year incremental cost: **€18,000–€20,000**

This allocation reflects license expansion and configuration optimization rather than greenfield deployment.

2. Cloud Security Posture Management (CSPM)

Functional Purpose

Given the organization's predominantly cloud-based architecture, continuous monitoring of cloud configuration is essential. Misconfigurations in identity and access management (IAM), storage permissions, or network segmentation represent high-risk attack vectors.

CSPM solutions provide:

- Continuous configuration assessment
- Detection of excessive IAM privileges
- Public exposure detection
- Compliance mapping (GDPR/NIS2 alignment)

Operational Benefits

- Reduced cloud misconfiguration risk
- Improved compliance documentation
- Faster detection of insecure deployments

Projected 2-year cost: **€8,000–€10,000**

This estimate includes moderate-tier CSPM tooling aligned with company scale.

3. SIEM Optimization and Log Retention Expansion

Functional Purpose

To support enhanced PD-WRL-001 and PD-WRL-007 responsibilities, logging infrastructure must be optimized to allow meaningful correlation and long-term visibility.

Improvements include:

- Increased log storage capacity
- Improved log normalization
- Alert tuning and rule refinement

Operational Benefits

- Reduced false positives
- Improved detection fidelity
- Better audit traceability

Projected 2-year cost: **€5,000**

This represents incremental infrastructure scaling rather than full platform replacement.

Integration with Workforce Strategy

Security tooling investment directly supports internal role expansion:

PD-WRL-001 (Defensive Cybersecurity) relies on EDR and SIEM for detection.

PD-WRL-007 (Vulnerability Analysis) leverages cloud configuration data and endpoint telemetry.

PD-WRL-004 (Infrastructure Support) configures and maintains defensive tools.

PD-WRL-003 (Incident Response) and **PD-WRL-006 (Threat Analysis)** validates tool effectiveness during simulated attacks.

DD-WRL-001 (Architect) ensures secure integration and architectural alignment.

Tools amplify human capability rather than replace it.

Risk Reduction Impact

The combined tooling investment contributes to:

- Reduced attacker dwell time
- Faster containment of compromised endpoints
- Reduced cloud exposure incidents
- Improved audit traceability
- Enhanced compliance alignment

This layer of automation and telemetry is essential to achieving measurable reductions in ransomware propagation risk and data exfiltration probability.

Financial Prudence

The total tooling investment of €25,000 over two years represents:

- 10% of the total cybersecurity transformation budget
- A moderate, scalable enhancement
- A cost-effective multiplier of workforce productivity

This investment ensures that the expanded internal security capabilities are operationally supported by appropriate technological controls.

4. External Regulatory Audit – ISO 27001 and NIS2 Compliance

Strategic Rationale - OG-WRL-016

As a healthcare-focused SaaS provider processing sensitive medical and personal data, the organization operates under strict regulatory obligations, including:

- **GDPR (General Data Protection Regulation)**
- **NIS2 Directive (Network and Information Security Directive)**
- ISO 27001 information security best practices

Given the regulatory exposure and the potential financial and reputational consequences of non-compliance, independent external validation is a necessary component of the 2-year cybersecurity strategy.

The organization will conduct **one external regulatory audit per year**, resulting in two formal assessments over the strategic planning period.

The total allocated budget is **€30,000 over two years (€15,000 per audit cycle)**.

Purpose of External Audit

The external audit serves multiple critical functions:

Independent Control Validation

- Assessment of implemented security controls
- Verification of policy adherence
- Evaluation of documentation completeness

Regulatory Alignment

- Validation of GDPR data protection measures
- Confirmation of NIS2 cybersecurity obligations

- Assessment of incident reporting readiness

Governance Transparency

- Evidence-based reporting to executive leadership
- Increased level of confidence
- Demonstration of due diligence

Gap Identification

- Identification of control deficiencies
- Structured remediation recommendations
- Improvement roadmap guidance

External audits reduce internal bias and provide objective oversight.

Financial Justification

The projected cost of approximately **€15,000 per audit cycle** reflects:

- Mid-size enterprise scope
- Cloud-based infrastructure
- Moderate complexity environment
- Independent third-party certification-level review

This cost is consistent with market pricing for ISO 27001 and NIS2 readiness assessments within Spain.

Risk Reduction Impact

Failure to comply with GDPR or NIS2 can result in:

- Administrative fines
- Mandatory reporting obligations
- Legal exposure
- Reputational damage
- Loss of client trust

In the healthcare sector, regulatory enforcement risk is significantly elevated due to the sensitivity of stored data.

The audit investment directly reduces:

- Probability of regulatory penalties

- Audit failure risk
- Compliance documentation gaps
- Board-level governance blind spots

Additionally, structured audit findings support continuous improvement in the organization's cybersecurity maturity model.

Strategic Integration with Workforce Plan

The external audit complements internal transformation by:

- Validating the work of the Cybersecurity Architect (DD-WRL-001)
- Reviewing detection and response processes (PD-WRL-001 and PD-WRL-003)
- Evaluating vulnerability management governance (PD-WRL-007)
- Assessing infrastructure hardening effectiveness (PD-WRL-004)

Thus, the audit functions not merely as a compliance requirement, but as a maturity benchmark for the entire cybersecurity transformation initiative.

Executive-Level Justification

The €30,000 investment over two years represents approximately **12% of the total cybersecurity transformation budget**, providing structured regulatory assurance and governance oversight.

In comparison to potential GDPR penalties—which can reach millions of euros—the cost of independent compliance validation is proportionally minimal and strategically justified.

This investment ensures that cybersecurity maturity is externally validated, measurable, and defensible before regulators, partners, and stakeholders.

5. External DFIR and Malware Analysis Service Contract

Strategic Rationale

Given the organization's exposure as a healthcare SaaS provider operating under GDPR and NIS2 regulatory obligations, the cybersecurity strategy includes the formal engagement of an external specialized cybersecurity firm to provide:

- Digital Forensics and Incident Response (DFIR)
- Advanced malware analysis
- Emergency containment support

While internal workforce capabilities are being expanded through structured training, advanced forensic investigation and reverse engineering of sophisticated malware require highly specialized expertise,

tooling, and experience that exceed the scope of internal roles. Therefore, the organization will establish a **two-year service contract with an external cybersecurity company**.

Scope of Services

The contracted external firm will provide:

Emergency Incident Response

- Rapid response deployment in case of ransomware or data breach
- On-site or remote forensic analysis
- Containment and eradication guidance

Advanced Malware Analysis

- Reverse engineering of malicious code
- Behavioral and static analysis
- Threat intelligence correlation

Digital Forensic Investigation

- Log and endpoint forensic acquisition
- Timeline reconstruction
- Evidence preservation compliant with legal standards

Post-Incident Reporting

- Root cause analysis
- Executive-level incident report
- Remediation recommendations

This engagement ensures structured and professional incident handling aligned with regulatory expectations.

Financial and Strategic Justification

The projected cost of the two-year DFIR service contract is €15,000, representing a controlled and proportionate investment within the overall €250,000 cybersecurity transformation budget.

In the healthcare sector, the financial and operational impact of a single ransomware incident can exceed €1 million when considering downtime, recovery costs, regulatory exposure, and reputational damage. By securing immediate access to specialized forensic and malware analysis expertise, the organization significantly reduces incident response time, containment delays, and recovery uncertainty.

This investment does not duplicate internal capabilities; rather, it complements them by providing advanced technical depth for high-impact scenarios. The service contract strengthens organizational resilience, supports regulatory defensibility under GDPR and NIS2, and ensures that critical incidents are managed with professional rigor.

The DFIR engagement therefore represents a cost-effective risk mitigation mechanism aligned with executive governance and operational continuity objectives.

6. Strategic Contingency Reserve

A contingency reserve of €4,000 is maintained within the 2-year cybersecurity budget to address unforeseen security requirements or emerging risks.

This reserve may be allocated to:

- Emergency tooling adjustments
- Temporary external specialist support
- Rapid mitigation of newly disclosed critical vulnerabilities
- Minor infrastructure upgrades following audit findings

Maintaining a contingency allocation ensures financial flexibility without exceeding the fixed €250,000 budget ceiling. It reflects prudent governance and acknowledges that cybersecurity risk evolves over time.

This reserve strengthens the adaptability and sustainability of the overall transformation strategy.

Executive Conclusion

The proposed investment plan transitions the organization from a reactive security posture to a structured, security-by-design model aligned with the NICE Workforce Framework.

Through targeted hiring, workforce upskilling, tooling enhancement, compliance validation, and incident preparedness measures, the organization significantly reduces systemic cybersecurity risk while maintaining financial discipline.

The €250,000 allocation over two years represents a controlled and strategically justified investment in long-term operational resilience.

AGREED AND ACCEPTED:

Lorela Elezaj	CEO	23.02.2026
NAME	**TITLE**	**DATE**

Luis Enrique Landaverde	**CISO**	**23.02.2026**
NAME	**TITLE**	**DATE**